

PLATEFORME DE VEILLE ISO/IEC 17025

Workflow complet de l'application

Fonctionnement métier, parcours par rôle, architecture, sécurité et exploitation

Périmètre actuel : modules 1 à 8 - Backend NestJS / PostgreSQL - Frontend Vue 3 / PrimeVue

Version documentaire du 20 septembre 2026

Sommaire

Sommaire	2
1. Finalité et périmètre actuel	4
2. Architecture générale	5
Principe de séparation	5
3. Connexion et sécurité de session	6
4. Rôles et responsabilités	7
Indicateurs du tableau de bord par rôle	7
5. Workflow métier complet	8
6. Sources et connecteurs	9
Protection réseau	9
7. Collecte, planification et reprise	10
8. Normalisation, déduplication et versionnement	11
9. Qualification et taxonomie	12
10. Validation, publication et archivage	13
11. Actions de suivi	14
12. Recherche, favoris et vues enregistrées	15
13. Abonnements et notifications	16
14. Rapports et téléchargements	17
15. Audit, santé et pilotage	18
16. Navigation frontend	19
17. Modèle de données résumé	20
18. Sécurité appliquée	21
19. Tests et contrôles de qualité	22

20. Scénarios pratiques par rôle	23
Administrateur	23
Responsable de veille	23
Opérateur de veille	23
Référent laboratoire	23
Lecteur	23
21. Exploitation quotidienne	24
Fin du workflow	24

1. Finalité et périmètre actuel

La plateforme centralise une veille normative, réglementaire, scientifique et d'accréditation destinée à un laboratoire conforme à ISO/IEC 17025. Elle transforme des informations externes en éléments structurés, qualifiés, validés, publiés puis suivis.

Module	Fonction principale	Résultat
1 - Accès	Authentification, utilisateurs et rôles	Session sécurisée et droits appliqués
2 - Sources	Sources et connecteurs	Origines configurées et testables
3 - Collecte	Collecte manuelle/planifiée	Données externes reçues
4 - Qualification	Taxonomie, pertinence, criticité	Information contextualisée
5 - Validation	Revue, publication, archivage, actions	Décision tracée et suivi attribué
6 - Consultation	Recherche, filtres, favoris, vues	Accès rapide à l'information
7 - Diffusion	Abonnements, notifications, rapports	Information diffusée et exportée
8 - Pilotage	Dashboard, audit, santé	Supervision selon le rôle

Changements intégrés dans cette version : cookie JWT HttpOnly, limitation des connexions, en-têtes Helmet, CORS contrôlé, validation stricte, protection SSRF des connecteurs, exports CSV sécurisés, tests backend/frontend et dépendances sans vulnérabilité connue au dernier audit.

2. Architecture générale

Couche 1 - Interface Vue 3

PrimeVue 4 + thème Aura

Router pour les pages et les droits

Pinia pour la session

Axios pour communiquer avec l'API

↓ Requêtes HTTPS/JSON avec cookie de session

Couche 2 - API NestJS

Contrôleurs : exposent les routes

Services : appliquent les règles métier

Guards : authentification et rôles

DTO : validation des entrées

Événements et scheduler : traitements asynchrones

↓ TypeORM, transactions et requêtes paramétrées

Couche 3 - PostgreSQL

Utilisateurs et rôles

Sources, connecteurs et collectes

Veilles, versions et taxonomie

Validations, actions, abonnements, notifications, rapports et audit

Principe de séparation

Une page Vue ne contacte jamais directement PostgreSQL. Elle appelle un service frontend, qui utilise Axios. Le contrôleur NestJS reçoit la requête, les Guards vérifient l'identité et les rôles, le DTO valide les données, puis le service métier utilise TypeORM. Cette séparation rend les responsabilités lisibles et testables.

3. Connexion et sécurité de session

Éta pe	Traitement	Protection
1	L'utilisateur saisit email et mot de passe	Le frontend n'enregistre pas le mot de passe
2	POST /api/v1/auth/login	5 essais/email et 20 essais/IP sur 15 minutes
3	Recherche de l'utilisateur	Compte obligatoire et statut ACTIVE
4	bcrypt.compare	Comparaison avec le hash, jamais avec un mot de passe en clair
5	Création du JWT	Identifiant, email et rôles signés
6	Cookie access_token	HttpOnly, SameSite=Lax, Secure en production, durée 8 h
7	GET /auth/me	Restaure la session au rechargement
8	POST /auth/logout	Supprime le cookie

Le frontend ne lit pas le jeton : le navigateur envoie automatiquement le cookie à l'API. Cela réduit l'exposition du JWT aux scripts exécutés dans la page.

```
// Extrait simplifié
response.cookie('access_token', accessToken, {
  httpOnly: true,
  sameSite: 'lax',
  secure: NODE_ENV === 'production',
  maxAge: 8 * 60 * 60 * 1000,
});
```

4. Rôles et responsabilités

Identifiants techniques enregistrés en base et dans le JWT : ADMIN, RESPONSABLE_VEILLE, OPERATEUR_VEILLE, REFERENT_LABORATOIRE et LECTEUR.

Fonction	ADMIN	RESP. VEILLE	OPÉRATEUR	RÉFÉRENT	LECTEUR
Tableau de bord	Oui	Oui	Oui	Oui	Oui
Utilisateurs / rôles	Gère	-	-	-	-
Taxonomie	Gère	Consulte	Consulte	Consulte	Consulte
Sources	Gère	Consulte/collecte	Crée/collecte	-	-
Veilles	Toutes	Toutes	À qualifier	Publiées + liées	Publiées
Qualification	Oui	Oui	Oui	-	-
Validation/publication	Oui	Oui	-	-	-
Actions de suivi	Gère	Gère	-	Assignées	-
Rapports / audit / santé	Oui	Oui	-	-	-
Abonnements / notifications	Oui	Oui	Oui	Oui	Oui

Le masquage des boutons dans Vue améliore l'expérience, mais la sécurité réelle reste assurée par JwtAuthGuard, RolesGuard et @Roles(...) dans NestJS.

Indicateurs du tableau de bord par rôle

Rôle	Indicateurs prioritaires
Administrateur	Sources actives/inactives, utilisateurs actifs, veilles à valider, critiques, actions ouvertes, erreurs et collectes récentes
Responsable veille	À valider, critiques, validées, publiées, actions ouvertes et erreurs de collecte
Opérateur	Sources actives, nouveaux éléments, éléments à qualifier, éléments qualifiés et collectes
Référent laboratoire	Actions qui lui sont assignées, retards, éléments publiés et publications critiques
Lecteur	Éléments publiés, publications critiques et publications récentes

5. Workflow métier complet

L'information suit sept étapes. Chaque sortie devient l'entrée contrôlée de l'étape suivante.

Étape	Acteurs	Traitement et résultat
1. Préparer	ADMIN, OPÉRATEUR	Créer les comptes et la taxonomie ; configurer la source et son connecteur.
2. Tester et collecter	ADMIN, RESPONSABLE, OPÉRATEUR	Tester le connecteur ; lancer ou planifier la collecte ; créer le journal.
3. Normaliser et dédupliquer	Système	Convertir vers le modèle commun ; comparer DOI, identifiant, URL et empreinte ; créer, mettre à jour ou classer en doublon.
4. Qualifier	ADMIN, RESPONSABLE, OPÉRATEUR	Renseigner type, pertinence, criticité, thèmes, domaines, laboratoires et mots-clés.
5. Réviser et décider	ADMIN, RESPONSABLE	Valider ou rejeter ; publier ou archiver ; conserver l'historique.
6. Agir et diffuser	RESPONSABLE, RÉFÉRENT, système	Attribuer les actions ; notifier les abonnés ; produire PDF, CSV et XLSX.
7. Piloter	ADMIN, RESPONSABLE	Analyser les KPI, l'audit, la santé des connecteurs et relancer si nécessaire.

Source fiable → collecte sécurisée → veille qualifiée → décision tracée → diffusion ciblée → action suivie → pilotage.

6. Sources et connecteurs

Une source décrit l'organisme et l'origine de l'information. Un connecteur contient la manière technique de la lire. Cette séparation autorise plusieurs stratégies sans modifier les informations métier de la source.

Type	Configuration	Comportement
IMPORT_MANUEL	config vide	Vérifie que le canal manuel est disponible
RSS / ATOM	feedUrl	Télécharge et analyse un flux RSS/Atom
API Crossref	provider, baseUrl, query, rows, mailto	Interroge l'API Crossref

Protection réseau

safe-http-client.ts vérifie le protocole, le port, le DNS et l'adresse IP avant chaque requête et chaque redirection. Les adresses privées, locales ou réservées sont refusées. La réponse est limitée à 5 Mo et le délai à 15 secondes. Crossref est limité au domaine api.crossref.org.

```
switch (connector.connectorType) {
  case 'IMPORT_MANUEL': return new ManualConnector();
  case 'RSS':
  case 'ATOM': return new RssConnector({ feedUrl });
  case 'API': return new CrossrefConnector(config);
}
```

7. Collecte, planification et reprise

Phase	Ce qui se passe
Déclenchement	POST /connectors/:id/run, /retry ou passage du scheduler
Verrouillage	Set en mémoire + verrou consultatif PostgreSQL évitent deux exécutions simultanées
Journal	CollectionRun mémorise démarrage, fin, statut et compteurs
Extraction	Le connecteur renvoie des ExternalItem
Traitement	Normalisation puis upsert/déduplication par WatchItemsService
Synthèse	received, created, updated, duplicates, errors
Fin	Dernière synchronisation et statut du connecteur mis à jour

Le scheduler s'exécute périodiquement, sélectionne les sources actives et compare la dernière synchronisation à la fréquence configurée (par exemple 30m, 6h, 12h ou 1j).

En cas d'échec : le journal conserve l'erreur, la page Santé du système montre le connecteur concerné et les rôles autorisés peuvent utiliser Réessayer.

8. Normalisation, déduplication et versionnement

Les formats RSS et Crossref sont différents. NormalizationService les ramène vers un modèle commun : identifiant externe, DOI, titre, résumé, URL, langue, date de publication, type de veille et données brutes.

Priorité	Clé de comparaison	Pourquoi
1	DOI	Identifiant scientifique stable
2	Identifiant externe + source	Référence propre au fournisseur
3	URL canonique	Même ressource web
4	Empreinte du contenu	Dernier recours sur titre/résumé/date

Si l'élément existe et que son contenu a changé, une WatchVersion conserve l'état antérieur avant mise à jour. Si rien n'a changé, le résultat est compté comme doublon. Cette logique explique pourquoi une nouvelle collecte peut recevoir 10 éléments et annoncer 10 doublons : ils étaient déjà connus.

9. Qualification et taxonomie

La qualification transforme un élément brut en information utile au laboratoire. L'opérateur, le responsable ou l'administrateur renseigne le type de veille, un score de pertinence, la criticité et les rattachements à la taxonomie.

Objet	Rôle
Topic / thème	Classe le sujet, avec relation parent-enfants
Domain	Décrit le domaine métier concerné
Laboratory	Indique le laboratoire impacté
Keyword	Ajoute des mots-clés normalisés
KeywordSynonym	Relie une variante lexicale à un mot-clé
WatchItemTopic / Keyword	Tables de liaison enrichies avec score et origine

L'enregistrement utilise une transaction : soit les valeurs simples et toutes les relations sont enregistrées ensemble, soit aucun changement partiel n'est conservé.

10. Validation, publication et archivage

Action	Rôles	Effet
Réviser	ADMIN, RESPONSABLE_VEILLE	Crée une Review et change le statut selon la décision
Publier	ADMIN, RESPONSABLE_VEILLE	Passe l'élément à PUBLIE et renseigne publishedAt
Archiver	ADMIN, RESPONSABLE_VEILLE	Passe l'élément à ARCHIVE
Commenter	Rôles du workflow	Conserve un commentaire métier dans l'historique

Après une publication réussie, ValidationService émet l'événement watch-item.published. NotificationsService le reçoit et crée les notifications pour les utilisateurs dont les abonnements correspondent à la source, au thème, au mot-clé ou au domaine.

```
await transaction.commit();
eventEmitter.emit(
  'watch-item.published',
  new WatchItemPublishedEvent(itemId),
);
```

11. Actions de suivi

Une action rattache une mesure concrète à un élément de veille : analyse d'impact, mise à jour documentaire, formation, adaptation d'une méthode ou autre action. Elle possède un responsable, une échéance, un statut et une description d'impact.

Statut	Sens	Transition habituelle
OPEN	Action créée	Démarrer
IN_PROGRESS	Action en cours	Terminer
DONE	Action réalisée	État final
CANCELLED	Action abandonnée	État final

ADMIN, RESPONSABLE_VEILLE et REFERENT_LABORATOIRE voient les actions. Le référent retrouve en priorité les actions qui lui sont assignées et celles qui sont en retard.

12. Recherche, favoris et vues enregistrées

La page Veilles interroge SearchService avec recherche plein texte PostgreSQL, filtres et pagination. La saisie déclenche une recherche temporisée afin d’éviter une requête à chaque frappe immédiate.

Fonction	Détail
Recherche	Titre et résumé via index GIN plein texte
Filtres	Statut, criticité, type, source, domaine, laboratoire, favoris
Tri	Publication, collecte, pertinence, criticité ou titre
Pagination	10, 20 ou 50 lignes par page
Favoris	Association personnelle utilisateur ↔ élément
Vues	Nom + filtres enregistrés en JSONB

Les rôles de consultation ne voient que les éléments publiés. Les rôles de qualification peuvent consulter les statuts de travail nécessaires à leur mission.

13. Abonnements et notifications

Chaque utilisateur authentifié peut s'abonner à une source, un thème, un mot-clé ou un domaine. Un abonnement actif utilise actuellement le canal IN_APP.

Événement	Traitement
Publication	Recherche des abonnements correspondants
Correspondance	Source ou taxonomie de l'élément publié
Création	Une Notification est créée pour chaque utilisateur concerné
Affichage	Le menu actualise le compteur non lu toutes les 15 secondes
Lecture	readAt est renseigné ; la notification peut ensuite être supprimée

Le badge du menu attire l'attention sans actualisation manuelle. Un événement navigateur met également le compteur à jour immédiatement après une action dans la page Notifications.

14. Rapports et téléchargements

ADMIN et RESPONSABLE_VEILLE choisissent la périodicité, la date de début, la date de fin et le format PDF, CSV ou XLSX. ReportsService sélectionne les éléments publiés de la période, génère le document, enregistre ses métadonnées puis expose une route de téléchargement.

Format	Usage	Protection / rendu
PDF	Lecture et archivage	Document PDF réel produit avec PDFKit
CSV	Échange simple	Neutralisation des cellules commençant par =, +, - ou @
XLSX	Analyse tabulaire	Classeur Excel avec colonnes structurées

Le nom téléchargé est construit à partir de la périodicité et des dates. L'interface affiche ensuite le rapport dans la liste et recharge automatiquement les données.

15. Audit, santé et pilotage

Composant	Fonction
AuditService	Enregistre l'utilisateur, l'action, l'entité, l'identifiant, les valeurs avant/après et la date
HealthService	Teste PostgreSQL et synthétise l'état/dernière synchronisation des connecteurs
DashboardService	Calcule des KPI différents selon le rôle
CollectionRun	Conserve les résultats et erreurs de chaque collecte

L'audit s'applique aux opérations sensibles : validation/publication, sources, actions et administration des utilisateurs. Il répond au besoin de traçabilité du système qualité.

16. Navigation frontend

Page	Route	Objectif
Connexion	/login	Ouvrir une session
Tableau de bord	/	Afficher les KPI du rôle
Veilles	/watch-items	Rechercher, filtrer, qualifier et consulter
Détail	/watch-items/:id	Voir l'historique, décider et créer une action
Qualification	/watch-items/:id/qualification	Renseigner la qualification
Sources	/sources	Gérer et collecter
Taxonomie	/taxonomy	Administrer les référentiels
Actions	/actions	Suivre les actions
Abonnements	/subscriptions	Choisir ses alertes
Notifications	/notifications	Lire et gérer ses alertes
Rapports	/reports	Générer et télécharger
Audit	/audit	Consulter la traçabilité
Santé	/health	Surveiller et relancer
Utilisateurs	/users	Administrer les comptes et rôles

Le routeur appelle `restoreSession()` avant la décision. Si la route exige une authentification ou des rôles absents, l'utilisateur est redirigé vers la connexion ou le tableau de bord.

17. Modèle de données résumé

Ensemble	Tables principales	Relations clés
Accès	users, roles, permissions	users_roles et roles_permissions
Acquisition	sources, connectors, collection_runs	source 1-N connecteurs et veilles
Veille	watch_items, watch_versions	versionnement et rattachement source
Taxonomie	topics, domains, laboratories, keywords, keyword_synonyms	liaisons N-N avec watch_items
Workflow	reviews, actions	décisions et mesures rattachées
Personnalisation	favorites, saved_views	données propres à l'utilisateur
Diffusion	subscriptions, notifications, reports	alertes et productions
Traçabilité	audit_logs	acteur, action, avant/après

18. Sécurité appliquée

Risque	Mesure appliquée
Vol du JWT par JavaScript	Cookie HttpOnly, plus de jeton dans localStorage
Brute force	Double limitation par IP et par email
Données inattendues	ValidationPipe whitelist + forbidNonWhitelisted
Accès sans droit	JwtAuthGuard + RolesGuard côté serveur
SSRF	Validation DNS/IP/redirect/port/protocole, taille et délai limités
CSV injection	Préfixage des cellules dangereuses
CORS	Liste explicite FRONTEND_URL + credentials
En-têtes HTTP	Helmet
Corps trop volumineux	Limite JSON et formulaire à 1 Mo
Schéma base	synchronize=false et migrations versionnées
Secrets	.env ignorés par Git

19. Tests et contrôles de qualité

Contrôle	État vérifié
Compilation backend	NestJS compile sans erreur
Lint backend	Oxlint sans erreur
Tests unitaires backend	6 fichiers, 8 tests
Test d'intégration	Connexion, cookie HttpOnly, session et accès protégé
Compilation frontend	Vue TypeScript et Vite réussissent
Tests frontend	Libellés et traduction d'erreurs
Migrations	5 migrations appliquées
Dépendances	0 vulnérabilité connue au dernier npm audit

Les tests ne remplacent pas une recette utilisateur complète. Avant une mise en production, ajouter des scénarios E2E couvrant collecte, qualification, publication, notifications et génération de chaque format de rapport.

20. Scénarios pratiques par rôle

Administrateur

Connexion → contrôle Santé → création des utilisateurs → attribution des rôles → gestion de la taxonomie → configuration des sources → surveillance des collectes → audit → rapports.

Responsable de veille

Connexion → consultation des alertes → revue des éléments qualifiés → validation/rejet → publication → création d'actions → génération de rapports → contrôle des erreurs.

Opérateur de veille

Connexion → test/collecte des sources → examen des nouveaux éléments → qualification → transmission implicite au responsable via le statut.

Référent laboratoire

Connexion → consultation des publications → lecture des actions assignées → passage de OPEN à IN_PROGRESS puis DONE → suivi des échéances.

Lecteur

Connexion → recherche dans les publications → favoris et vues enregistrées → abonnements → lecture des notifications.

21. Exploitation quotidienne

Moment	Vérification
Démarrage	PostgreSQL disponible, migrations appliquées, une seule instance sur le port 3000
Chaque jour	Santé des connecteurs, erreurs de collecte, veilles critiques, actions en retard
Chaque semaine	Sources inactives, doublons, éléments à qualifier/valider, rapports
Avant livraison	build, lint, tests, audit des dépendances, sauvegarde base et secrets

Chaîne de valeur complète : une source fiable alimente un connecteur sécurisé ; la collecte crée des éléments normalisés sans doublons ; l'équipe les qualifie et les valide ; la publication déclenche la diffusion ; les actions et l'audit ferment la boucle de maîtrise.

Fin du workflow

Ce document décrit l'état réel du projet au moment de sa génération. La documentation d'arborescence associée détaille ensuite chaque fichier qui implémente ce processus.